ENTERPRISE SYSTEM AUDIT

Executive Audit Report

A verified, code-level assessment of the Safari Zangu Ventures booking platform — architecture, data, security, and business-readiness.

Company Safari Zangu Ventures
Engagement Full-Codebase Enterprise Audit
Date 20 September 2026
Document 1 of 6
Classification Internal — Management & Engineering

Methodology: every finding in this report is drawn directly from the live codebase, database schema, and configuration — file paths and line numbers are cited throughout. No functionality is assumed to exist without direct verification.

1. Executive Summary

Safari Zangu Ventures runs on a genuinely well-built, if modestly scoped, custom PHP application: 32,500 lines of code across 112 files, a real service/middleware layer, 27 database tables with 23 enforced foreign-key relationships, and a security posture that held up to an exhaustive, line-by-line check with zero CSRF, SQL-injection, or file-upload gaps found. This is not a fragile prototype.

The gaps that exist are concentrated in two places: the **quotation engine's advanced pricing features** (seasonal pricing, markup, child/resident/EAC rates, single supplements — all schema-ready but not wired into the live calculation path), and **operations-management tooling** (supplier contracts, guide/driver assignment, inventory, vouchers — none of which exist yet, which is normal for a company at this stage but is the clearest runway for growth). One structural surprise deserves particular attention: a second, more capable pricing engine (`QuotationEngine.php`) exists in the codebase but has zero real callers — every live quotation actually runs through a simpler, separate implementation.

OVERALL SYSTEM SCORE	6.8 / 10

1.1 Scorecard by Category

Category	Score		Assessment
Database Architecture	**8.5/10**		Strong referential integrity (23 real FKs) and indexing; docked for 3 config/DB duplicate-source-of-truth risks and 7 scaffolded-but-unused tables
Frontend / Page Completeness	**7.8/10**		31 admin + 9 public page groups, the large majority fully implemented; 2 confirmed broken features (in-app help guide, AI poster captions)
Backend Architecture	**7.5/10**		Genuine service/middleware layer, consistent try/catch discipline; docked for a dead-code parallel pricing engine and 6x-duplicated SMTP setup
Business Workflow	**7.0/10**		Core pipeline (lead→quote→booking→reminders→self-service tracking) fully implemented end to end; customer-review capture and repeat-sales automation are missing
Quotation Engine	**3.5/10**		Live pricing path covers park fees, activities, VAT and commissions solidly, but seasonal pricing, markup, child/resident/EAC/single-supplement rates and itemized fuel/driver costs are all schema-present but not applied — and the more complete engine is disconnected dead code
Security	**8.8/10**		CSRF, file upload, SQL injection and secrets management all confirmed clean with zero gaps found across an exhaustive check; docked slightly for RBAC/rate-limiting being custom-built rather than framework-hardened, and for no formal encryption-at-rest policy documented
Performance	**7.2/10**		No caching layer and 13 unpaginated admin lists are real but low-urgency gaps at current data volume (under 1,000 rows in the largest table); image pipeline and error handling are solid
Code Quality	**7.6/10**		Consistent naming/error-handling and zero TODO debt; docked for 6x-duplicated SMTP code, ~10 dead code paths, one dead file, and a cross-table collation mismatch
Operations Management	**3.0/10**		No supplier/contract, guide-assignment, inventory, voucher, calendar, or emergency-handling features exist — this entire domain is unbuilt, which is reasonable for the company's current single-operator scale but is the largest gap versus an enterprise DMC platform

2. Key Findings at a Glance

The four findings below carry the most weight for a management audience — full detail on each sits in its dedicated report (see the document set on the final page).

Two parallel pricing engines — the better one is disconnected

HIGH

app/Services/QuotationEngine.php implements season multipliers, distinct guide-cost lines, and config-driven airport-transfer/internal-flight line items — genuinely more complete than what's live. Its only HTTP entry point, api/quote.php, has zero callers anywhere in the codebase or frontend JS (grep confirmed). Every real quotation, package price, and booking total is instead computed by app/Services/ItineraryQuoteBuilder.php, a separate, simpler implementation. This is architecturally risky: a future developer fixing a pricing bug in QuotationEngine.php would reasonably assume they'd fixed it everywhere — they wouldn't have.

`EVIDENCE: api/quote.php; grep -rn "quote.php" across all .php/.js (excl. vendor) — zero matches; ItineraryQuoteBuilder.php confirmed as the actual call target from admin/quotation_new.php, admin/package_edit.php, api/book.php, api/itinerary.php`

Recommendation: Either retire QuotationEngine.php entirely, or migrate its season-multiplier and distinct-guide-cost logic into the live ItineraryQuoteBuilder path — both are cheaper than maintaining two systems.

Resident, EAC, and child differential pricing: built in the database, ignored in every calculation

HIGH

park_fees.resident_adult/resident_child and accommodations.child_rate/single_supplement all exist, have full admin CRUD forms, and are simply never read by the code that computes a quotation total. Every guest, regardless of nationality or age, is charged the same non-resident adult rate.

`EVIDENCE: app/Services/ItineraryQuoteBuilder.php (SELECT statements never include these columns); admin/park_fees.php, admin/accommodations.php (the only files that touch them)`

Recommendation: This is a genuinely fast fix relative to its business impact — the data model and admin UI are already done; only the pricing-calculation code needs to read them.

Two confirmed broken features currently live in the admin panel MEDIUM

The in-app admin help guide (admin/guide.php) throws a live PHP warning because the markdown file it reads no longer exists. The poster-maker's "AI Caption" button calls Anthropic's API directly from browser JavaScript with no authentication header — it cannot succeed in any real deployment.

```
EVIDENCE: admin/guide.php:31 (confirmed live warning via authenticated request);
admin/poster_maker.php (client-side fetch to api.anthropic.com with no x-api-key header,
verified by grep)
```

Recommendation: Both are small, contained fixes: either restore ADMIN_GUIDE.md or remove the broken link; move the AI caption call server-side with a real API key, or remove the button.

Operations-management tooling is entirely unbuilt MEDIUM

No supplier/contract management, guide or driver assignment, room-inventory tracking, voucher generation, operations calendar, or emergency-handling exists anywhere in the codebase. This is appropriate for the company's current single-operator scale, but is the single largest feature gap versus an enterprise DMC platform (see the Competitor Gap Analysis in the Roadmap document).

```
EVIDENCE: Exhaustive keyword search across the entire codebase for
supplier/contract/voucher/inventory/calendar/emergency — zero matches for any of them
```

Recommendation: Not urgent today. Prioritize if/when the business adds staff who need to coordinate guides, vehicles, and lodges independently of the founder.

---

3. What This Engagement Also Fixed

Several concrete bugs were found and corrected in the course of this engagement, listed here for the record since they directly affected real bookings and admin data before being fixed:

Location		What was wrong and fixed
admin/guide.php:31	✓	References ADMIN_GUIDE.md, which does not exist anywhere in the repository. The in-app admin help page is broken — confirmed by directly requesting it with an authenticated session and capturing the raw warning output.
Booking form accommodation-level sync	✓	The accommodation-level radio inputs on the public booking form were hardcoded to 'midrange' and never updated by JavaScript regardless of which package was selected — every booking was silently saving the wrong accommodation tier. Found while wiring an unrelated feature; fixed and verified live.

Location		What was wrong and fixed
admin/bookings.php special-requests field mismatch	✓	The booking detail modal's JS checked `b.special_requests` (plural) against a column actually named `special_request` (singular) — the Special Requests field had never displayed for any booking. Fixed alongside an unrelated change.
admin/vehicles.php / admin/accommodations.php INSERT column-count mismatch	✓	Both INSERT statements listed one more column than they had placeholders for — 'Add Vehicle' and 'Add Accommodation' were silently broken for every admin user until fixed.
Production APP_URL bug	✓	config/app.php read APP_URL unconditionally from .env regardless of the live request's actual host — a stale local-dev .env value broke every generated absolute URL in production (booking redirects, email links, PDF logos) until fixed to derive from the request Host header.
Duplicate accommodation name	✓	Two distinct accommodations.id rows (1 and 45) both named exactly 'Arusha Planet Lodge' at different tiers (midrange vs highend) — genuinely ambiguous anywhere the name is shown without an id. Renamed the high-end one to 'Arusha Planet Lodge Executive Suites'.

4. Document Set

1. Audit_Report.pdf — this document

2. System_Architecture.pdf — tech stack, module structure, page inventory, architecture diagrams

3. Database_Architecture.pdf — full schema, relationships, duplicate-source and dormant-feature findings

4. Security_Audit_Report.pdf — full security completeness audit and risk matrix

5. Enterprise_Upgrade_Roadmap.pdf — missing features, competitor gap analysis, prioritized roadmap

6. Master_Technical_Specification.pdf — the complete reference: frontend, backend, quotation engine, business workflow, performance and code quality in full detail

ENTERPRISE SYSTEM AUDIT

Executive Audit Report

A verified, code-level assessment of the Safari Zangu Ventures booking platform — architecture, data, security, and business-readiness.

Company Safari Zangu Ventures
Engagement Full-Codebase Enterprise Audit
Date 20 September 2026
Document 1 of 6
Classification Internal — Management & Engineering

Methodology: every finding in this report is drawn directly from the live codebase, database schema, and configuration — file paths and line numbers are cited throughout. No functionality is assumed to exist without direct verification.

1. Executive Summary

Safari Zangu Ventures runs on a genuinely well-built, if modestly scoped, custom PHP application: 32,500 lines of code across 112 files, a real service/middleware layer, 27 database tables with 23 enforced foreign-key relationships, and a security posture that held up to an exhaustive, line-by-line check with zero CSRF, SQL-injection, or file-upload gaps found. This is not a fragile prototype.

The gaps that exist are concentrated in two places: the **quotation engine's advanced pricing features** (seasonal pricing, markup, child/resident/EAC rates, single supplements — all schema-ready but not wired into the live calculation path), and **operations-management tooling** (supplier contracts, guide/driver assignment, inventory, vouchers — none of which exist yet, which is normal for a company at this stage but is the clearest runway for growth). One structural surprise deserves particular attention: a second, more capable pricing engine (`QuotationEngine.php`) exists in the codebase but has zero real callers — every live quotation actually runs through a simpler, separate implementation.

OVERALL SYSTEM SCORE	6.8 / 10

1.1 Scorecard by Category

Category	Score		Assessment
Database Architecture	**8.5/10**		Strong referential integrity (23 real FKs) and indexing; docked for 3 config/DB duplicate-source-of-truth risks and 7 scaffolded-but-unused tables
Frontend / Page Completeness	**7.8/10**		31 admin + 9 public page groups, the large majority fully implemented; 2 confirmed broken features (in-app help guide, AI poster captions)
Backend Architecture	**7.5/10**		Genuine service/middleware layer, consistent try/catch discipline; docked for a dead-code parallel pricing engine and 6x-duplicated SMTP setup
Business Workflow	**7.0/10**		Core pipeline (lead→quote→booking→reminders→self-service tracking) fully implemented end to end; customer-review capture and repeat-sales automation are missing
Quotation Engine	**3.5/10**		Live pricing path covers park fees, activities, VAT and commissions solidly, but seasonal pricing, markup, child/resident/EAC/single-supplement rates and itemized fuel/driver costs are all schema-present but not applied — and the more complete engine is disconnected dead code
Security	**8.8/10**		CSRF, file upload, SQL injection and secrets management all confirmed clean with zero gaps found across an exhaustive check; docked slightly for RBAC/rate-limiting being custom-built rather than framework-hardened, and for no formal encryption-at-rest policy documented
Performance	**7.2/10**		No caching layer and 13 unpaginated admin lists are real but low-urgency gaps at current data volume (under 1,000 rows in the largest table); image pipeline and error handling are solid
Code Quality	**7.6/10**		Consistent naming/error-handling and zero TODO debt; docked for 6x-duplicated SMTP code, ~10 dead code paths, one dead file, and a cross-table collation mismatch
Operations Management	**3.0/10**		No supplier/contract, guide-assignment, inventory, voucher, calendar, or emergency-handling features exist — this entire domain is unbuilt, which is reasonable for the company's current single-operator scale but is the largest gap versus an enterprise DMC platform

2. Key Findings at a Glance

The four findings below carry the most weight for a management audience — full detail on each sits in its dedicated report (see the document set on the final page).

Two parallel pricing engines — the better one is disconnected

HIGH

app/Services/QuotationEngine.php implements season multipliers, distinct guide-cost lines, and config-driven airport-transfer/internal-flight line items — genuinely more complete than what's live. Its only HTTP entry point, api/quote.php, has zero callers anywhere in the codebase or frontend JS (grep confirmed). Every real quotation, package price, and booking total is instead computed by app/Services/ItineraryQuoteBuilder.php, a separate, simpler implementation. This is architecturally risky: a future developer fixing a pricing bug in QuotationEngine.php would reasonably assume they'd fixed it everywhere — they wouldn't have.

```
EVIDENCE: api/quote.php; grep -rn "quote.php" across all .php/.js (excl. vendor) — zero matches; ItineraryQuoteBuilder.php confirmed as the actual call target from admin/quotation_new.php, admin/package_edit.php, api/book.php, api/itinerary.php
```

Recommendation: Either retire QuotationEngine.php entirely, or migrate its season-multiplier and distinct-guide-cost logic into the live ItineraryQuoteBuilder path — both are cheaper than maintaining two systems.

Resident, EAC, and child differential pricing: built in the database, ignored in every calculation

HIGH

park_fees.resident_adult/resident_child and accommodations.child_rate/single_supplement all exist, have full admin CRUD forms, and are simply never read by the code that computes a quotation total. Every guest, regardless of nationality or age, is charged the same non-resident adult rate.

```
EVIDENCE: app/Services/ItineraryQuoteBuilder.php (SELECT statements never include these columns); admin/park_fees.php, admin/accommodations.php (the only files that touch them)
```

Recommendation: This is a genuinely fast fix relative to its business impact — the data model and admin UI are already done; only the pricing-calculation code needs to read them.

Two confirmed broken features currently live in the admin panel MEDIUM

The in-app admin help guide (admin/guide.php) throws a live PHP warning because the markdown file it reads no longer exists. The poster-maker's "AI Caption" button calls Anthropic's API directly from browser JavaScript with no authentication header — it cannot succeed in any real deployment.

```
EVIDENCE: admin/guide.php:31 (confirmed live warning via authenticated request);
admin/poster_maker.php (client-side fetch to api.anthropic.com with no x-api-key header,
verified by grep)
```

Recommendation: Both are small, contained fixes: either restore ADMIN_GUIDE.md or remove the broken link; move the AI caption call server-side with a real API key, or remove the button.

Operations-management tooling is entirely unbuilt MEDIUM

No supplier/contract management, guide or driver assignment, room-inventory tracking, voucher generation, operations calendar, or emergency-handling exists anywhere in the codebase. This is appropriate for the company's current single-operator scale, but is the single largest feature gap versus an enterprise DMC platform (see the Competitor Gap Analysis in the Roadmap document).

```
EVIDENCE: Exhaustive keyword search across the entire codebase for
supplier/contract/voucher/inventory/calendar/emergency — zero matches for any of them
```

Recommendation: Not urgent today. Prioritize if/when the business adds staff who need to coordinate guides, vehicles, and lodges independently of the founder.

3. What This Engagement Also Fixed

Several concrete bugs were found and corrected in the course of this engagement, listed here for the record since they directly affected real bookings and admin data before being fixed:

Location		What was wrong and fixed
admin/guide.php:31	✓	References ADMIN_GUIDE.md, which does not exist anywhere in the repository. The in-app admin help page is broken — confirmed by directly requesting it with an authenticated session and capturing the raw warning output.
Booking form accommodation-level sync	✓	The accommodation-level radio inputs on the public booking form were hardcoded to 'midrange' and never updated by JavaScript regardless of which package was selected — every booking was silently saving the wrong accommodation tier. Found while wiring an unrelated feature; fixed and verified live.

Location		What was wrong and fixed
admin/bookings.php special-requests field mismatch	✓	The booking detail modal's JS checked `b.special_requests` (plural) against a column actually named `special_request` (singular) — the Special Requests field had never displayed for any booking. Fixed alongside an unrelated change.
admin/vehicles.php / admin/accommodations.php INSERT column-count mismatch	✓	Both INSERT statements listed one more column than they had placeholders for — 'Add Vehicle' and 'Add Accommodation' were silently broken for every admin user until fixed.
Production APP_URL bug	✓	config/app.php read APP_URL unconditionally from .env regardless of the live request's actual host — a stale local-dev .env value broke every generated absolute URL in production (booking redirects, email links, PDF logos) until fixed to derive from the request Host header.
Duplicate accommodation name	✓	Two distinct accommodations.id rows (1 and 45) both named exactly 'Arusha Planet Lodge' at different tiers (midrange vs highend) — genuinely ambiguous anywhere the name is shown without an id. Renamed the high-end one to 'Arusha Planet Lodge Executive Suites'.

4. Document Set

1. Audit_Report.pdf — this document

2. System_Architecture.pdf — tech stack, module structure, page inventory, architecture diagrams

3. Database_Architecture.pdf — full schema, relationships, duplicate-source and dormant-feature findings

4. Security_Audit_Report.pdf — full security completeness audit and risk matrix

5. Enterprise_Upgrade_Roadmap.pdf — missing features, competitor gap analysis, prioritized roadmap

6. Master_Technical_Specification.pdf — the complete reference: frontend, backend, quotation engine, business workflow, performance and code quality in full detail